



PDF Download
3589335.3651463.pdf
11 March 2026
Total Citations: 22
Total Downloads: 421



Published: 13 May 2024

Citation in BibTeX format

WWW '24: The ACM Web Conference
2024
May 13 - 17, 2024
Singapore, Singapore

Conference Sponsors:
SIGWEB

 Latest updates: <https://dl.acm.org/doi/10.1145/3589335.3651463>

SHORT-PAPER

A Study of Vulnerability Repair in JavaScript Programs with Large Language Models

TAN KHANG LE, Simon Fraser University, Burnaby, BC, Canada

SABA ALIMADADI, Simon Fraser University, Burnaby, BC, Canada

STEVEN Y. KO, Simon Fraser University, Burnaby, BC, Canada

Open Access Support provided by:

Simon Fraser University

A Study of Vulnerability Repair in JavaScript Programs with Large Language Models

Tan Khang Le
Simon Fraser University
Burnaby, British Columbia, Canada
khang_le@sfu.ca

Saba Alimadadi
Simon Fraser University
Burnaby, British Columbia, Canada
saba@sfu.ca

Steven Y. Ko
Simon Fraser University
Burnaby, British Columbia, Canada
steveyko@sfu.ca

ABSTRACT

In recent years, JavaScript has become the most widely used programming language, especially in web development. However, writing secure JavaScript code is not trivial, and programmers often make mistakes that lead to security vulnerabilities in web applications. Large Language Models (LLMs) have demonstrated substantial advancements across multiple domains, and their evolving capabilities indicate their potential for automatic code generation based on a required specification, including automatic bug fixing. In this study, we explore the accuracy of LLMs, namely ChatGPT and Bard, in finding and fixing security vulnerabilities in JavaScript programs. We also investigate the impact of context in a prompt on directing LLMs to produce a correct patch of vulnerable JavaScript code. Our experiments on real-world software vulnerabilities show that while LLMs are promising in automatic program repair of JavaScript code, achieving a correct bug fix often requires an appropriate amount of context in the prompt.

CCS CONCEPTS

• **Security and privacy** → **Software and application security**; *Web application security*; • **Computing methodologies** → **Machine learning**.

KEYWORDS

JavaScript, Automatic Program Repair, Large Language Models, Prompt Engineering, CWE

ACM Reference Format:

Tan Khang Le, Saba Alimadadi, and Steven Y. Ko. 2024. A Study of Vulnerability Repair in JavaScript Programs with Large Language Models. In *Companion Proceedings of the ACM Web Conference 2024 (WWW '24 Companion)*, May 13–17, 2024, Singapore, Singapore. ACM, New York, NY, USA, 4 pages. <https://doi.org/10.1145/3589335.3651463>

1 INTRODUCTION

Despite the prevalence and popularity of JavaScript programs, understanding and analyzing them is challenging due to their heterogeneous, dynamic, and asynchronous nature. As a result, developers

are prone to making mistakes and exposing many JavaScript programs to security vulnerabilities [4]. Developers commonly use static analysis and fuzzing techniques to mitigate such bugs. However, this process can be tedious in terms of understanding and identifying the vulnerabilities, and subsequently modifying the code to repair the bugs.

With the rapid development of artificial intelligence, Large Language Models (LLMs) are increasingly trained on large codebases with the goal of automatic code generation based on specifications from user inputs [2, 3, 10, 19]. This empowers LLMs to generate code in different ways, given some context such as the developer's intention expressed in code comments. Although LLMs may occasionally produce code with security bugs [14, 15], when coupled with suitable security-aware tooling during code generation, LLMs have the potential to enhance a software developer's productivity [12], thereby reducing the risks of introducing new security bugs. As such, the research community has been actively investigating the effectiveness of LLMs in finding and fixing code vulnerabilities [1, 6, 13, 17, 18]. Most of these studies, however, have focused on programming languages such as C/C++ and Verilog. As such, we currently do not have much insight into the role of LLMs in repairing security vulnerabilities in a dynamic language such as JavaScript.

In this paper, we study the utilization of black-box, “off-the-shelf” LLMs, namely ChatGPT and Bard, in the automatic program repair of JavaScript code. Furthermore, we investigate the effect of context (or *cues*) in a prompt on LLMs' ability to generate accurate security patches. We aim to address the following research questions:

- **RQ1:** How accurate are LLMs in finding and fixing vulnerabilities in JavaScript programs?
- **RQ2:** How does the amount of context in a prompt impact the effectiveness of LLMs in producing a correct patch of vulnerable JavaScript code?

To answer these questions, we conduct a study on over 20 of the most common software vulnerabilities. We compare three distinct prompt templates with varying degrees of contextual *cues*. These templates serve to guide LLMs in repairing vulnerable JavaScript code. In total, the study involves 60 prompts for two LLMs, covering the 20 identified vulnerabilities across the three proposed prompt templates¹. The experimental results show that ChatGPT and Bard, on average, accurately generate patches for 71.66% and 68.33% of cases, respectively (RQ1). Furthermore, we find that the more context provided in a prompt, the better ChatGPT and Bard perform in producing a correct patch, with an improvement of up to 55% in accuracy (RQ2).

¹Our repair prompts and testing results are publicly available at: <https://doi.org/10.5281/zenodo.10783763>

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

WWW '24 Companion, May 13–17, 2024, Singapore, Singapore

© 2024 Copyright held by the owner/author(s). Publication rights licensed to ACM.
ACM ISBN 979-8-4007-0172-6/24/05
<https://doi.org/10.1145/3589335.3651463>

2 RELATED WORK

In this section, we review the related work on code security and vulnerability as well as program repair with large language models.

2.1 Code Security and Vulnerability

Due to the critical importance of safeguarding systems against potential threats and breaches, there has been much research into code security and vulnerability, providing insights into the nature of security bugs and weaknesses. Specifically, as system errors and vulnerabilities continue to grow over time, automated program repair [8] emerges as a research field that focuses on a class of techniques for producing source code-level patches for such bugs. A classical approach for automated program repair is to turn the program repair problem into a search problem. For example, Le Goues et al. [7] used genetic programming to search for a program variant that addresses a bug in the given program without changing the required functionality or producing new errors. An alternative approach demonstrated by Nguyen et al. [9] is to use semantic analysis for the automatic construction of patches.

The development community also actively engages in studying and documenting vulnerabilities in software and hardware, such as the Common Weakness Enumeration (CWE). CWE functions as a categorization system designed for both hardware and software vulnerabilities, consisting of over 600 categories, namely buffer overflows, race conditions, and cross-site scripting. Every year, MITRE publishes a list of the top 25 most dangerous software weaknesses (CWE Top 25) [16], which serves as a benchmark for evaluating many automated program repair tools.

2.2 Program Repair with Large Language Models (LLMs)

With the rise of LLMs in recent years, the field of automated program repair has seen many major advancements. Much research has shown the potential of LLMs in automated bug fixing for both software and hardware programs. Particularly, Wu et al. [18] evaluated five different LLMs and four automatic program repair tools on two Java vulnerability benchmarks. With regard to hardware vulnerabilities, Ahmad et al. [1] attempted to repair hardware bugs in Verilog programs automatically using LLMs. From the security perspective, the study by Pearce et al. [13] on zero-shot vulnerability repair demonstrated promising results of using LLMs for finding and fixing security bugs in both software and hardware programs, written in Python, C, and Verilog. Furthermore, recent research has leveraged LLMs to produce highly secured code through controlled code generation [6] or to detect and patch side-channel vulnerabilities in software [17].

3 METHODOLOGY

In our study, given an input *prompt* that instructs LLMs to find and fix a *vulnerability* within a provided JavaScript code snippet, we investigate the accuracy of the responses generated by these LLMs. An example of an input prompt and the corresponding response returned by ChatGPT are shown in Table 1.

In the given example, we ask LLMs to fix a bug, namely an “Out-of-bound Write” error, in the given JavaScript code. Particularly, the issue in the code is that an `Int16Array` object is created with a

Table 1: An example of an input prompt and the response returned by LLM.

Prompt	Response
Fix the bug in the following code:	Here is the corrected code:
<pre> ...js let idSequence = new Int16Array(3); idSequence[0] = 123; idSequence[1] = 234; idSequence[2] = 345; idSequence[3] = 456; // No effect console.log(idSequence[3]) // undefined ... </pre>	<pre> ...js let idSequence = new Int16Array(4); // Fix the length to 4 idSequence[0] = 123; idSequence[1] = 234; idSequence[2] = 345; idSequence[3] = 456; console.log(idSequence[3]); // Accessing the valid // index 3 ... </pre>

length of 3, but there is a write operation to the element at index 3, which will take no effect because the valid indices in this array are 0, 1, and 2. In this scenario, ChatGPT successfully identifies and fixes the bug by increasing the array length to 4, effectively validating element access at index 3. We note that various approaches may exist for repairing vulnerable code. However, as long as LLMs can produce a functional and secured patch, we consider it a success as our focus lies in determining the capability of LLMs to identify a solution rather than exhaustively exploring all potential fixes.

3.1 Prompt Design

To investigate the role of different levels of context in the prompts on the generated repair, we design three different prompt templates based on the degree of provided context. First, a context-free (c.f.) prompt comprises solely a repair instruction and a vulnerable JavaScript code. There are no hints or additional information regarding the anticipated vulnerability. Second, a context-sensitive (c.s.) prompt is similar to a context-free prompt but with the inclusion of the name of the expected vulnerability, such as “Out-of-bound Write” and “Integer Overflow.” Last, a context-rich (c.r.) prompt encloses comments along with the vulnerable JavaScript code, providing an exhaustive explanation of the vulnerability within the code as well as how an attacker could exploit it. While in an ideal scenario, a developer with the knowledge of a vulnerability context should be able to repair it directly without relying on LLMs, explaining the vulnerability to LLMs as in c.r. prompts might be beneficial for seeking suggestions or exploring different perspectives on potential fixes. This collaborative approach could enhance a developer’s productivity in vulnerability repair. A sample prompt for each template is shown in Table 2.

Table 2: Samples of the proposed prompt templates.

Template	Sample
context-free (c.f.)	Fix the bug in the following code: <pre> ```js const urlParams = new URLSearchParams(window. location.search); const username = urlParams.get('username'); const trimmedName = username.trim(); ``` </pre>
context-sensitive (c.s.)	Fix the "NULL Pointer" vulnerability in the following code: <pre> ```js const urlParams = new URLSearchParams(window. location.search); const username = urlParams.get('username'); const trimmedName = username.trim(); ``` </pre>
context-rich (c.r.)	Fix the bug in the following code: <pre> ```js // Get the query parameters from the current // URL const urlParams = new URLSearchParams(window. location.search); // Get the username value const username = urlParams.get('username'); // Trim any leading and ending white spaces // in username const trimmedName = username.trim(); // Users can control the query parameters so // an attacker may set username value to // undefined or null // causing the program to crash when it // attempts to call the trim method ``` </pre>

3.2 Vulnerability Selection

To ensure that our study is practical and relevant to the real world, we leverage the latest 2023 CWE Top 25 List [16]. However, not all vulnerabilities listed in the top 25 list are related to JavaScript, a few of them are specific to other programming languages. For example, "CWE-416: Use After Free" is only applicable to C and C++ as described in MITRE's documentation. Consequently, we carefully identify and select 20 out of the 25 vulnerabilities that are

Table 3: Relevant vulnerabilities selected from 2023 CWE Top 25 List.

ID	Description
CWE-20	Improper Input Validation
CWE-22	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')
CWE-77	Improper Neutralization of Special Elements used in a Command ('Command Injection')
CWE-78	Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')
CWE-79	Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')
CWE-89	Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
CWE-94	Improper Control of Generation of Code ('Code Injection')
CWE-125	Out-of-bounds Read
CWE-190	Integer Overflow or Wraparound
CWE-269	Improper Privilege Management
CWE-276	Incorrect Default Permissions
CWE-287	Improper Authentication
CWE-306	Missing Authentication for Critical Function
CWE-434	Unrestricted Upload of File with Dangerous Type
CWE-476	NULL Pointer Dereference
CWE-502	Deserialization of Untrusted Data
CWE-787	Out-of-bounds Write
CWE-798	Use of Hard-coded Credentials
CWE-862	Missing Authorization
CWE-863	Incorrect Authorization

most relevant to JavaScript. The complete list of the identified 20 vulnerabilities is presented in Table 3.

4 EXPERIMENT AND EVALUATION

In our study, we conduct a systematic experiment on two publicly available LLMs, namely ChatGPT and Bard.

4.1 Experiment Details

Based on the proposed three prompt templates and the identified 20 vulnerabilities, we formulate a total of 60 prompts. Specifically, each of the 20 vulnerabilities is replicated across the three prompt templates with varying degrees of contextual *cues*, ranging from no additional context to comprehensive detail.

In our experiment, we feed our prompts to the LLMs and subsequently evaluate the correctness of their responses in repairing the anticipated vulnerability within the given JavaScript code snippet. Additionally, as LLMs can be heavily biased in a continuous dialogue [20], we create a new and separate conversation for each prompt to avoid such biases and ensure an impartial evaluation.

4.2 Results and Discussion

RQ1: How accurate are LLMs in finding and fixing vulnerabilities in JavaScript programs?

Table 4: Performance results of large language models on finding and fixing vulnerabilities in JavaScript code.

Vulnerability ID	ChatGPT			Bard		
	c. f.	c. s.	c. r.	c. f.	c. s.	c. r.
CWE-20	✗	✓	✓	✗	✓	✓
CWE-22	✗	✓	✓	✗	✓	✓
CWE-77	✓	✓	✓	✓	✓	✓
CWE-78	✓	✓	✓	✗	✓	✓
CWE-79	✓	✓	✓	✓	✓	✓
CWE-89	✓	✓	✓	✓	✓	✓
CWE-94	✓	✓	✓	✓	✓	✓
CWE-125	✗	✓	✓	✗	✓	✓
CWE-190	✗	✗	✓	✗	✗	✗
CWE-269	✗	✗	✗	✗	✓	✓
CWE-276	✓	✓	✓	✓	✓	✓
CWE-287	✗	✗	✓	✗	✓	✓
CWE-306	✗	✗	✓	✗	✓	✓
CWE-434	✗	✓	✓	✗	✓	✓
CWE-476	✓	✓	✓	✓	✗	✗
CWE-502	✗	✓	✓	✓	✓	✓
CWE-787	✓	✓	✓	✓	✓	✓
CWE-798	✗	✓	✓	✗	✗	✗
CWE-862	✗	✓	✓	✗	✗	✓
CWE-863	✗	✓	✓	✗	✓	✓
Accuracy	8/20	16/20	19/20	8/20	16/20	17/20

Table 4 presents the performance results of ChatGPT and Bard on repairing various vulnerabilities, with different levels of context, in JavaScript programs. Particularly, ChatGPT correctly finds and fixes 43 out of 60 cases, achieving an accuracy of 71.66%. On the other hand, Bard has a slightly lower accuracy of 68.33%, with 41 accurate repairs out of 60.

RQ2: How does the amount of context in a prompt impact the effectiveness of LLMs in producing a correct patch of vulnerable JavaScript code?

The results in Table 4 also demonstrate that the provided context in a prompt has a positive impact on LLMs' capability to find and fix vulnerabilities. When there is no additional context as in c. f. prompts, ChatGPT and Bard perform poorly in repairing security bugs, each achieving an accuracy of 40%. However, when compared with c. f. prompts, ChatGPT shows improved performance on c. s. and c. r. prompts, showcasing an improved accuracy of 80% and 95%, respectively. Similarly, Bard experiences a better accuracy of 80% and 85% when tested with c. s. and c. r. prompts, respectively.

4.3 Threats to Validity

The validity of the evaluations drawn from our experimental results is subject to a few threats. First, we use the public version of both ChatGPT [11] and Bard [5] in our testing (accessed in November 2023), which can change and evolve over time. Second, the correctness of the repaired JavaScript code produced by LLMs is verified manually and, thus, subject to human biases. Last, we acknowledge that more studies are required to draw more accurate conclusions.

5 CONCLUSION

In this study, we have identified 20 common vulnerabilities from the CWE Top 25 List that are most relevant to JavaScript and proposed three prompt templates with varying degrees of context. Based on these vulnerabilities and templates, we have formulated a total of 60 repair prompts for our study with LLMs, namely ChatGPT and Bard. Our experimental results show that ChatGPT excels with a promising accuracy of 71.66%, while Bard closely follows with an accuracy of 68.33%, in the automatic program repair task of vulnerable JavaScript code. Furthermore, our findings indicate that increased contextual information in a repair prompt positively influences the performance of LLMs in finding and fixing vulnerabilities, leading to a significant boost in accuracy of up to 55%.

REFERENCES

- [1] Baleegh Ahmad, Shailja Thakur, Benjamin Tan, Ramesh Karri, and Hammond Pearce. 2023. Fixing Hardware Security Bugs with Large Language Models. *arXiv preprint arXiv:2302.01215* (2023).
- [2] Jacob Austin, Augustus Odena, Maxwell Nye, Maarten Bosma, Henryk Michalewski, David Dohan, Ellen Jiang, Carrie Cai, Michael Terry, Quoc Le, et al. 2021. Program synthesis with large language models. *arXiv preprint arXiv:2108.07732* (2021).
- [3] Aakanksha Chowdhery, Sharan Narang, Jacob Devlin, Maarten Bosma, Gaurav Mishra, Adam Roberts, Paul Barham, Hyung Won Chung, Charles Sutton, Sebastian Gehrmann, et al. 2023. Palm: Scaling language modeling with pathways. *Journal of Machine Learning Research* 24, 240 (2023), 1–113.
- [4] Douglas Crockford. 2008. *JavaScript: The Good Parts: The Good Parts*. "O'Reilly Media, Inc".
- [5] Google. 2023. *Bard*. <https://bard.google.com/>
- [6] Jingxuan He and Martin Vechev. 2023. Large language models for code: Security hardening and adversarial testing. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security*. 1865–1879.
- [7] Claire Le Goues, ThanhVu Nguyen, Stephanie Forrest, and Westley Weimer. 2011. Genprog: A generic method for automatic software repair. *Ieee transactions on software engineering* 38, 1 (2011), 54–72.
- [8] Claire Le Goues, Michael Pradel, Abhik Roychoudhury, and Satish Chandra. 2021. Automatic program repair. *IEEE Software* 38, 4 (2021), 22–27.
- [9] Hoang Duong Thien Nguyen, Dawei Qi, Abhik Roychoudhury, and Satish Chandra. 2013. Semfix: Program repair via semantic analysis. In *2013 35th International Conference on Software Engineering (ICSE)*. IEEE, 772–781.
- [10] Erik Nijkamp, Bo Pang, Hiroaki Hayashi, Lifu Tu, Huan Wang, Yingbo Zhou, Silvio Savarese, and Caiming Xiong. 2022. Codegen: An open large language model for code with multi-turn program synthesis. *arXiv preprint arXiv:2203.13474* (2022).
- [11] OpenAI. 2023. *ChatGPT*. <https://chat.openai.com/>
- [12] Hammond Pearce, Baleegh Ahmad, Benjamin Tan, Brendan Dolan-Gavitt, and Ramesh Karri. 2022. Asleep at the keyboard? assessing the security of github copilot's code contributions. In *2022 IEEE Symposium on Security and Privacy (SP)*. IEEE, 754–768.
- [13] Hammond Pearce, Benjamin Tan, Baleegh Ahmad, Ramesh Karri, and Brendan Dolan-Gavitt. 2023. Examining zero-shot vulnerability repair with large language models. In *2023 IEEE Symposium on Security and Privacy (SP)*. IEEE, 2339–2356.
- [14] Gustavo Sandoval, Hammond Pearce, Teo Nys, Ramesh Karri, Siddharth Garg, and Brendan Dolan-Gavitt. 2023. Lost at c: A user study on the security implications of large language model code assistants. *arXiv preprint arXiv:2208.09727* (2023).
- [15] Mohammed Latif Siddiq, Shafayat H Majumder, Maisha R Mim, Sourov Jajodia, and Joanna CS Santos. 2022. An Empirical Study of Code Smells in Transformer-based Code Generation Techniques. In *2022 IEEE 22nd International Working Conference on Source Code Analysis and Manipulation (SCAM)*. IEEE, 71–82.
- [16] T. M. C. (MITRE). 2023. *CWE Top 25 Most Dangerous Software Weaknesses*. <https://cwe.mitre.org/top25/index.html>
- [17] M Caner Tol and Berk Sunar. 2023. ZeroLeak: Using LLMs for Scalable and Cost Effective Side-Channel Patching. *arXiv preprint arXiv:2308.13062* (2023).
- [18] Yi Wu, Nan Jiang, Hung Viet Pham, Thibaud Lutellier, Jordan Davis, Lin Tan, Petr Babkin, and Sameena Shah. 2023. How Effective Are Neural Networks for Fixing Security Vulnerabilities. *arXiv preprint arXiv:2305.18607* (2023).
- [19] Frank F Xu, Uri Alon, Graham Neubig, and Vincent Josua Hellendoorn. 2022. A systematic evaluation of large language models of code. In *Proceedings of the 6th ACM SIGPLAN International Symposium on Machine Programming*. 1–10.
- [20] Wayne Xin Zhao, Kun Zhou, Junyi Li, Tianyi Tang, Xiaolei Wang, Yupeng Hou, Yingqian Min, Beichen Zhang, Junjie Zhang, Zican Dong, et al. 2023. A survey of large language models. *arXiv preprint arXiv:2303.18223* (2023).